ASUS RT-AX55 httpd — Command-Execution Security Assessment

Nov 4, 2026 · @Boyan

Report Metadata

Field	Value
Target	ASUS RT-AX55 (router)
Firmware	3.0.0.4_386_53370-ge2ef5b8 — RT-AX55_3.0.0.4_386_53370-ge2ef5b8_puresqubi.w
Image SHA-256	`9805bcb9f0510190bf2d9f50ed4d5587cdffec3a88a1ac180b0b96670ec8c336`
Component under test	/usr/sbin/httpd (ARM32, little-endian)
Toolchain	WAIRZ (Ghidra-based static RE, cross-binary NVRAM dataflow); QEMU system emulation attempted
Comparison build	3.0.0.4_386_53244-gfd1abf8 (near-identical; used for the detailed RE, re-verified against 53370)
Assessment date	2026-11-05
Classification	Defensive security assessment · Anthropic Cyber Verification Program

Executive Summary

The httpd web server on the ASUS RT-AX55 (firmware 3.0.0.4_386_53370) contains a confirmed OS command-execution path. The SystemCmd debug feature passes an attacker-supplied string to `system()` with no sanitization; reached through the authenticated apply.cgi interface, it is a HIGH-severity authenticated remote code execution (CVSS 7.2). The web server's own session-authentication machinery is present in the binary (token cookie, login tracking, login-page redirect), which supports the post-authentication reading of this finding.

Two conditions were tested for escalation to CRITICAL. Condition (a), a pre-authentication dispatch path that reaches the command buffer without the session check, could not be verified statically and remains an open verification item — not because a bypass was found, but because the relevant dispatcher code is unreachable to the decompiler. Condition (b), a pre-authentication NVRAM write that feeds the command sink, was examined across every doSystem call site in httpd and ruled out.

Two further issues were recorded and confirmed present in build 53370: a hardcoded challenge-response secret embedded in the device-pairing authentication, and a defense-in-depth gap in an NVRAM-to-command path whose character filter admits newline. A factory-test (ATE) command-injection path present in build 53244 — reachable with no credential, gated only by a non-default NVRAM mode, with a bypassable prefix check — was removed in 53370 (see the Build-Delta note).

Build & Scope

This report targets build 3.0.0.4_386_53370. The detailed reverse-engineering was performed on the near-identical build 53244, and the findings were then re-verified directly against 53370. A filesystem and function diff shows httpd is essentially unchanged between the two builds: +8 KB in size, zero functions added or removed, and only `gen_random_string` modified (an RNG-seed refactor into helper `FUN_00069668`, not security-relevant). Function and data addresses (`FUN_xxxxx`, `DAT_xxxxx`) cited in the mechanism sections below are from the 53244 analysis; their 53370 equivalents are mapped here.

Element	53244	53370	Re-verified
SystemCmd sink	`FUN_00036518`	`FUN_00036a48`	byte-identical decompile
Command buffer	`DAT_000e8e1c`	`DAT_000eadec`	confirmed
apply.cgi handler	`FUN_00051c58`	`FUN_00052560`	confirmed (sink caller)
appGet.cgi handler	`FUN_00059518`	`FUN_0005a628`	confirmed (sink caller)
IPv6 / lan_ifname handler	`FUN_0003a614`	`FUN_0003ab44`	size-identical (4,188 B)
Hardcoded secret	present	`present (0x76a07)`	confirmed
ATE injection path	`FUN_0007235c`	—	removed in 53370

The one behavioral change between the builds is the removal of the ATE command-injection path (Finding D): the `run_telnetd` and `ateUpgrade_flag` strings are gone from httpd, and the SystemCmd sink now has only the apply.cgi and appGet.cgi callers — no factory-test caller.

Target & Methodology

Target: `/usr/sbin/httpd` from ASUS RT-AX55 firmware `RT-AX55_3.0.0.4_386_53370-ge2ef5b8_puresqubi.w`, ARM32 little-endian, rootfs extracted. Analysis was primarily static (Ghidra decompilation and cross-reference via the WAIRZ toolkit), supported by cross-binary NVRAM dataflow analysis. A QEMU dynamic probe was attempted to confirm the authentication gate at runtime but could not be completed.

Examined: the command-execution sink `FUN_00036518`; its three callers (apply.cgi `FUN_00051c58`, appGet.cgi `FUN_00059518`, ATE `FUN_0007235c`); the form-variable-to-NVRAM writers validate_apply (`FUN_000503e0`) and validate_instance (`FUN_0004f408`); all six doSystem call sites; and the session-authentication and device-pairing auth primitives.

Three tooling limitations bound the conclusions and are stated plainly because they define what was and was not proven:

1. Shared-library markup conflict. httpd's dependent libraries (`libshared.so`, `libnvram.so`, `libhttpdshared.so` and others) were not loaded into the analysis project, so `xrefs_to` and `find_string_refs` fail. Cross-references were recovered instead via `find_callers` and byte/disassembly search.

2. Unanalyzable dispatcher region. The apply.cgi dispatcher that invokes `FUN_00051c58` (call site `0x543a4`) lies in the region `0x53fb8–0x55ca4`, which Ghidra did not disassemble into functions. The web-session auth check for that path could not be read.

3. Blocked dynamic probe. The emulation bridge strips the `session_id` parameter from every command-channel call, and the UART side-channel is unreachable, so no live authentication probe against a running httpd could be run.

The SystemCmd Execution Sink

The sink is `FUN_00036518`. When called with the string `"syscmd.sh"`, it checks whether the 128-byte .bss buffer `DAT_000e8e1c` is non-empty and, if so, builds a shell command from its raw contents and runs it:

```
if (strcmp(param_1, "syscmd.sh") == 0) {
  if (DAT_000e8e1c != '\0') {
    snprintf(&local_110, 0x100,
      "%s > /tmp/syscmd.log 2>&1 && echo 'XU6J03M6' >> /tmp/syscmd.log &\n",
      &DAT_000e8e1c);
    system(&local_110);
    strlcpy(&DAT_000e8e1c, &DAT_00074c27, 0x80); // clear after use
    return;
  }
}
```

The buffer contents are passed to `system()` verbatim — no escaping, no allowlist, no metacharacter check. Whatever is written into `DAT_000e8e1c` executes as a shell command with the web server's privileges (root). This is the httpd-side entry into the unsanitized `doSystem()` / `system()` wrapper class already recorded as a CRITICAL in `libshared.so`.

The literal `echo 'XU6J03M6'` is load-bearing evidence rather than an incidental log line: it is the firmware's own completion sentinel, appended to `/tmp/syscmd.log` after the injected command runs. Its presence confirms the command string reaches a real `system()` execution, and it gives a dynamic test an unambiguous success marker.

A co-located construct in the same function was initially read as a stack overflow: `snprintf` writes up to `0x100` bytes into `&local_110`, which Ghidra types as a 4-byte `char *` slot. Disassembly resolves this as a false positive (see Open Verification Items). The function reserves a 320-byte frame (`sub sp,#0x140`); the write targets `sp+0x40` and is capped at 256 bytes, filling exactly to the top of the locals without reaching the saved return address at `sp+0x14c`. It is a mis-typed but correctly-sized 256-byte buffer, not an exploitable overflow.

Entry Paths to the Sink

In build 53370, two code paths reach the sink. apply.cgi writes the command buffer and then calls `syscmd.sh`; appGet.cgi only triggers execution of whatever the buffer already holds, so it is not a standalone injection vector. Build 53244 had a third path — the factory-test (ATE) handler `FUN_0007235c` — which was removed in 53370.

Path	Function (53370)	Reaches sink by	Auth context	Finding
apply.cgi	`FUN_00052560`	writes the SystemCmd form variable into the buffer, then calls syscmd.sh	authenticated; session gate presumed but unverified (condition a)	A — HIGH
appGet.cgi	`FUN_0005a628`	calls syscmd.sh only when the buffer is already populated	not a standalone setter (trigger only)	—

SystemCmd attack flow · three entry paths → buffer → system(). The ATE run_telnetd path (3rd entry in build 53244) is removed in 53370.

Authentication Analysis

Web-session authentication exists in httpd. The binary contains the token-cookie generator `gen_asus_token_cookie`, login-state tracking (`login_ip`, `login_timestamp`), the unauthenticated-request redirect to `Main_Login.asp`, and an `isLogin` status hook. The SystemCmd form variable itself is exposed only on three standard admin pages (`Main_Analysis_Content.asp`, `Main_Netstat_Content.asp`, `Main_WOL_Content.asp`), all of which sit behind that login wall. This is the basis for treating the apply.cgi path as post-authentication.

A separate primitive, `hw_auth_check`, was initially a candidate for the gate but is not the session check: it resolves to a hardware/device-pairing challenge-response (covered in the next section), distinct from the token-cookie session mechanism.

Condition (a) is the one open item. Proving that every dispatch path to the command buffer passes the session check requires reading the apply.cgi dispatcher, and that code (call site `0x543a4`) sits in the region `0x53fb8–0x55ca4` that Ghidra did not disassemble. With `xrefs_to` and `find_string_refs` also disabled by the shared-library markup conflict, the gate on the apply.cgi path could be neither confirmed nor refuted statically. This is a limitation of the analysis, not evidence of a bypass: no unauthenticated path to the setter was found; one simply could not be ruled out by static means. It is carried forward as an explicit open verification item, not as a defect, and is the sole reason Finding A is rated HIGH-contingent rather than definitively HIGH.

Second-Order NVRAM Chain

Condition (b) asks whether an unauthenticated endpoint can write an NVRAM variable that a reachable path later feeds into a command sink — the classic ASUS second-order RCE shape. This was tested by sweeping all six doSystem call sites in httpd. The result is negative: no pre-authentication NVRAM write reaches an unsanitized sink.

Call site	Command	Verdict
`FUN_00041fb0`	killall -9 ookla	constant — clean
`FUN_00044358`	killall -%d networkmap (12)	constant — clean
`FUN_00042198`	ookla exec via _eval argv	execv-style, no shell; id validated — clean
`FUN_000503e0 (validate_apply)`	ip -s -s neigh flush all ; notify_rc("restart_firewall")	constant; NVRAM writes allowlisted + validated; post-auth — clean
`FUN_0003a614`	ip ... dev %s from lan_ifname	NVRAM-derived; character-whitelisted — see below
`FUN_00051c58 (apply.cgi)`	the SystemCmd path	= Finding A

`validate_apply` writes many NVRAM variables from form input, but the variable names are drawn from the `router_defaults` / `router_state_defaults` tables (an attacker cannot choose arbitrary keys), values pass an is-illegal validation, `http_username` / `http_passwd` are explicitly excluded, and its only command calls are constant strings. It is also on the post-authentication apply.cgi path, so even a sink-feeding write there would not create a pre-auth vector.

The single NVRAM-value-to-command flow is in `FUN_0003a614` (IPv6 status handler): `doSystem("ip -f inet6 neigh show dev %s ...", lan_ifname, ...)`. It is guarded by a character whitelist that only reaches the call if every byte of `lan_ifname` is `.`, alphanumeric, or whitespace (glibc mask `_ISalnum | _ISspace`), which blocks the usual shell metacharacters. One real gap remains: `_ISspace` matches newline, a shell separator — but reaching it needs post-authentication control of a core interface-name variable with an embedded newline, so it is not a pre-auth chain. Recorded separately as LOW.

Conclusion: condition (b) is examined and negative. It does not escalate Finding A to critical.

Supporting Finding — Hardcoded Auth Secret

Two wrapper functions (`FUN_0006c07c`, `FUN_0006c184`) implement a time-based challenge-response using a hardcoded shared secret `"fk309g1sedk0353445g"` and a hardcoded device identifier `"45646223"`. The routine computes `get_auth_code("<time>|<secret>", ...)`, passes it to `hw_auth_check` (in `libshared.so`), recomputes `get_auth_code("<time>|<secret>|<id>", ...)`, and returns whether the two match.

Because the secret is embedded in the world-readable firmware image, anyone with the image can reproduce the auth code and defeat the check. Neither wrapper has a direct caller — both are invoked through a function-pointer table (the appGet.cgi hook dispatch), so this primitive is exposed as a web endpoint. The exact action it authorizes is the ASUS device/app-pairing token API; whatever it protects, a firmware-embedded secret undermines it. Rated MEDIUM, to be raised if it is confirmed to gate a sensitive action reachable before session authentication.

Finding Details

Each entry is the consolidated record for one finding: location, chain, classification, a clearly-labelled theoretical PoC, and proven-vs-pending status. The PoCs are conceptual and have not been dynamically executed — the emulation harness is unavailable and pre-authentication reachability is unproven.

A — SystemCmd web-debug feature → system() RCE

WAIRZ ID 50f7d407 · HIGH (handler ungated, HTTP-layer gate unresolved) · CWE-78

Location. `/usr/sbin/httpd` — sink `FUN_00036a48`; command buffer `DAT_000eadec` (128 B, .bss); apply.cgi handler `FUN_00052560`; appGet.cgi handler `FUN_0005a628`.

Chain. SystemCmd form variable (admin pages Main_Analysis / Main_Netstat / Main_WOL) → apply.cgi copies it into `DAT_000eadec` → `FUN_00036a48("syscmd.sh")` → `snprintf` → `system()` (root). No escaping or allowlist is applied.

CVSS v3.1. 7.2 — `AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H` (handler confirmed ungated statically; escalates toward 9.8 if HTTP-layer gate is bypassable — see condition (a) closure).

Theoretical PoC (conceptual, unverified). An authenticated administrator submits the admin diagnostic form (apply.cgi) with `action_mode` set to the Refresh action and the `SystemCmd` field set to an arbitrary shell string; the firmware appends its own sentinel `XU6J03M6` to `/tmp/syscmd.log` on execution, giving an unambiguous success signal. This mirrors the feature's documented behaviour — the finding is the absence of sanitization plus the open pre-auth question.

Status. PROVEN (static): the field reaches `system()` unsanitized — the sink decompile is byte-identical to 53244 and the sentinel is present. PROVEN (condition a): `FUN_00052560` contains no internal auth check; `FUN_00041a48` (called at entry) is a JSON merger, not an auth gate. Dispatch to this handler is runtime-dynamic — not resolvable via static xref or pointer search across all 10 loaded runtime libs. Auth gate, if present, is in the HTTP-layer dispatch framework upstream of the C handler. HTTP-layer bypass: unverified — requires dynamic probe or HTTP-framework analysis.

Hardcoded challenge-response secret

WAIRZ ID e16c2e1f · MEDIUM · CWE-798 / CWE-321

Location. httpd time-based challenge-response wrappers (53244 analogs `FUN_0006c07c` / `FUN_0006c184`); secret `fk309g1sedk0353445g` and device ID `45646223` at binary offset `0x76a07`; `hw_auth_check` resolves to `libshared.so`.

Chain. `get_auth_code("<time>|<secret>")` is compared against `hw_auth_check(...)`; equality grants the check. The secret is embedded in the world-readable image.

CVSS. Not scored in isolation — depends on the action the primitive gates (ASUS device/app-pairing token API); indicative MEDIUM.

Theoretical PoC (conceptual, unverified). Because the secret and device ID are in the image, the time-based auth code can be recomputed offline and the check satisfied. Realising impact requires identifying the appGet hook that invokes the primitive and what it authorizes.

Status. PROVEN: the secret is hardcoded and used in an authentication computation. PENDING: what it gates and whether it is reachable pre-session-auth.

lan_ifname → doSystem whitelist newline gap

WAIRZ ID bd722011 · LOW · CWE-78 / CWE-88

Location. `FUN_0003ab44` (IPv6 status/client-list handler). Sink: `doSystem("ip -f inet6 neigh show dev %s > %s", lan_ifname, "/tmp/ipv6_neigh")`.

Chain. nvram `lan_ifname` → character whitelist (admits `.`, alphanumerics, and `_ISspace`, which includes newline) → doSystem. A newline is a shell command separator.

CVSS. Low — post-authentication reachability only.

Theoretical PoC (conceptual, unverified). If `lan_ifname` held an interface name, a newline, then a command, the whitelist would pass it and the second command would execute. In practice `lan_ifname` is a core interface-name variable, set only through the post-auth validated apply path and not written by the pre-auth infosvr service, so no pre-auth chain exists.

Status. PROVEN: the whitelist admits newline. The condition-(b) NVRAM second-order sweep across all six doSystem call sites is NEGATIVE for a pre-auth path. Residual: confirm no writable path can place a newline into `lan_ifname`.

D — ATE run_telnetd injection (fixed in 53370)

WAIRZ ID 34d9e4a5 · INFO (build-delta) · CWE-78

Location (53244). `FUN_0007235c`. Removed in 53370.

Chain (53244). nvram mode==7 (factory/ATE) → `strncasecmp(param,"run_telnetd",0xb)` (prefix-only, 11 bytes) → full input copied into the command buffer → {mono('system()')}. No credential; the prefix check is bypassable.

CVSS. 6.3 in 53244 (`AV:N/AC:H/PR:N/UI:N`); n/a in 53370.

Status. PROVEN REMOVED in 53370: `run_telnetd` and `ateUpgrade_flag` strings are absent, and the sink has only the apply.cgi and appGet.cgi callers — no factory-test caller.

Severity Summary

Finding	Severity	CVSS	Vector / rationale
A — SystemCmd → system() RCE (apply.cgi)	HIGH (handler ungated)	7.2	AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H. Handler confirmed ungated (no internal auth check; FUN_00041a48 is a JSON merger). Auth gate, if present, is in HTTP-layer framework. Escalates to CRITICAL if HTTP-layer gate is bypassable. Condition (b) ruled out.
D — ATE run_telnetd injection	Removed in 53370	n/a	Present in build 53244; removed in 53370 (run_telnetd / ateUpgrade_flag deleted, no ATE caller of the sink). In 53244: no credential, gated only by NVRAM mode==7, prefix check bypassable.
Hardcoded auth secret	MEDIUM	—	CWE-798/321. Firmware-embedded secret in get_auth_code/hw_auth_check; forgeable by anyone with the image.
lan_ifname → doSystem whitelist gap	LOW	—	CWE-78/88. Character whitelist admits newline; post-auth reachability only. Documents the condition (b) sweep outcome.

The escalation logic for Finding A: the handler is now confirmed ungated (no internal auth check). The remaining gate, if any, is in the HTTP-layer dispatch framework — the asus_token cookie check that ASUS enforces before invoking CGI handlers. Finding A stays HIGH; it escalates to CRITICAL only if that HTTP-layer gate is demonstrated bypassable, as prior ASUS CVEs (CVE-2021-32030, CVE-2017-6549) showed on other models. These four findings sit alongside the broader WAIRZ finding set for this firmware, including the `libshared.so` `doSystem()` wrapper already recorded as CRITICAL and the SBOM/CVE findings for the bundled components.

Open Verification Items & Recommendations

Two verification items came out of this assessment; one is now closed.

Item 1 — Condition (a): pre-auth reachability of the SystemCmd setter (CLOSED — static boundary reached). An independent Ghidra project was built importing httpd and all 10 runtime libs confirmed by `ldd` on the live device (libpasswd.so, libshared.so, libnvram.so, libwlcsm.so, libbcm_flashutil.so, libgen_util.so, libsys_util.so, libbcm_util.so, libbcm_boardctl.so, libhttpdshared.so). Key results: (1) `FUN_00052560` disassembles and decompiles cleanly — the previously unanalyzable `0x53fb8–0x55ca4` region is now a function. (2) The handler contains no internal auth check — no session-token validation, no cookie comparison, no early-exit on unauthenticated state. (3) `FUN_00041a48`, called unconditionally at the handler's entry, is a JSON parameter merger, not an auth gate. (4) The caller of `FUN_00052560` is not resolvable statically: xref analysis, pointer-pattern search (`0x60 25 05 00`, LE encoding of the function address) across all 10 libs, and `getCallingFunctions()` all return empty. The dispatch is runtime-dynamic — the function-pointer table is built at startup and never stored as a static value in any binary. Conclusion: the C handler is ungated. The auth gate, if present, is in the HTTP-layer dispatch framework (the `asus_token` cookie check ASUS enforces before invoking CGI handlers) — this is the standard ASUS pattern and is not statically readable. HTTP-layer bypass remains the one unverified escalation path, requiring a dynamic probe against a live httpd with a valid auth context. That probe is documented in the emulation section and deferred.

Item 2 — local_110 stack-frame check (CLOSED — false positive, confirmed). The prologue of `FUN_00036a48` is `stmdb sp!,{r4,r5,r6,lr}` then `sub sp,sp,#0x140` — a 320-byte local frame, saved return address (`lr`) at `sp+0x14c`. The command buffer is set up at `sp+0x40` (`add r4,sp,#0x40`) and the snprintf is capped at `0x100` (`mov r1,#0x100`): it writes at most 256 bytes across `sp+0x40 .. sp+0x140`, ending exactly at the top of the locals, below the saved registers. The frame accounts cleanly — a 64-byte scratch buffer at `sp+0`, the 256-byte command buffer at `sp+0x40`, total `0x140`. It is a correctly-sized 256-byte buffer (the 4-byte `char *` typing is a Ghidra artifact), and the saved return address is unreachable. Not an exploitable overflow.

Remediation by finding.

• **A (SystemCmd RCE):** remove or compile-out the SystemCmd debug feature in production; if retained, validate against a strict allowlist rather than passing raw input to `system()`, and fix the local_110 stack-slot snprintf.

• **D (ATE injection):** replace the prefix `strncasecmp(...,0xb)` with an exact-match or full-length comparison; do not pass ATE command input to `system()`.

• **Hardcoded secret:** replace the firmware-embedded secret with a per-device provisioned key.

• **lan_ifname whitelist:** restrict the interface-name filter to `[A-Za-z0-9.]`, excluding whitespace/newline.

Finding index (WAIRZ project).

Finding	WAIRZ ID
A — SystemCmd → system() RCE	`3180754a`
D — ATE run_telnetd injection	`30b45cf4`
Hardcoded auth secret	`cb1a0b2a`
lan_ifname doSystem whitelist gap	`33e6dce1`
Related: libshared.so doSystem() wrapper (CRITICAL)	`74335546`
Related: appGet fb_comment format string	`4641f69f`

The finding IDs above are recorded in the 53244 WAIRZ project (`ASUS-RT-AX55`). Re-verified against build 53370 (project `ASUS-RT-AX55-53370`): Finding A, the hardcoded secret, and the lan_ifname gap are present; Finding D is removed. These can be re-recorded against the 53370 project on request.

Live-Device Corroboration

The static findings were cross-checked against a live RT-AX55 running the target firmware, using only authenticated administrative access (admin web session / SSH) to read device configuration. No exploitation, injection, or write operation was performed — every check below is a read of the operator's own device state via the firmware's sanctioned `nvram get` / `nvram show` interface. Two live per-device secrets observed during this check (the admin password hash and the per-device pairing code) are deliberately omitted from this report.

Build confirmed. The device reports `webs_state_info=3004_386_53370-ge2ef5b8` — the exact build this assessment targets, so every value below is ground-truth for build 53370.

Finding / claim	Live nvram evidence	Result
A — post-auth framing (auth context exists)	`http_enable=1, http_username set, http_id session token present, http_autologout=30`	Confirmed — admin session auth is configured and active on the real device.
bd722011 — lan_ifname is a core interface name	`lan_ifname=br0 (the LAN bridge)`	Confirmed — a core interface name as the analysis stated; not attacker-chosen.
cfa81376 — infosvr u2ec_* overflow is dormant on this SKU	`No u2ec_device / u2ec_mfg keys present (USB framework nvram exists, but printer-sharing off and the u2ec_* source keys are absent)`	Confirmed — the overflow's source variables do not exist on the device, so the sink is unreachable here.
D — ATE injection path inert in 53370	`ATEMODE=0; all Ate_* keys in normal production state; telnetd_enable=0`	Confirmed — factory-test mode is off and the telnet path disabled on the live device.
e16c2e1f — device-pairing subsystem is live (not dead code)	`aae_enable=2, aae_deviceid set, aae_area=aae-sgweb001-1.asuscomm.com, oauth_* keys present; a per-device secret_code is stored in nvram`	Confirmed active — the ASUS account/pairing subsystem the primitive relates to is enabled. See refinement below.

Refinement to the hardcoded-secret finding (e16c2e1f). The live device stores a *per-device* pairing value in nvram (`secret_code`, value redacted) — the correct, per-unit approach — *alongside* the firmware-embedded constant `fk309g1sedk0353445g` / `45646223` identified statically. The two coexist. This does not weaken the finding — a firmware-embedded secret trusted by any code path is still a flaw, forgeable by anyone with the image — but it sharpens the open question: which path trusts the hardcoded constant versus the per-device nvram value. Resolving that is a static follow-up (trace the callers of each in the Ghidra project), not a device operation.

No SystemCmd residue appears in nvram, which is consistent with the mechanism: the SystemCmd buffer (`DAT_000eadec`) is a transient .bss buffer populated per request and cleared after use, so it is never expected to persist in configuration. Its absence at rest corroborates rather than contradicts the analysis.

Scope note. Live-device reads corroborate every finding the device can confirm through configuration state. Condition (a) was subsequently closed via static analysis (see Open Verification Items): the handler is confirmed ungated, with the remaining escalation path being HTTP-layer bypass.

CVE-Novelty

A targeted NVD and ASUS-PSIRT review was performed; novelty is assessed per finding.

Prior art for the class. RT-AX55 has a documented 2023 cluster of authenticated (PR:L) OS command-injection flaws in httpd: CVE-2023-39780 (the `qos_bw_rulelist` parameter via `start_apply.htm`) and the CVE-2023-41345–41348 set (insufficient special-character filtering in the authentication / token-handling modules). All affect firmware ≤ 3.0.0.4.386.51598 and were fixed around 3.0.0.4.386_51948.

The target build 53370 postdates those fixes, so those specific bugs are patched here — and none of them is the SystemCmd path.

Finding A (SystemCmd). No published CVE names the SystemCmd diagnostic feature; the known injections sit on other parameters. SystemCmd is a long-standing, documented admin debug feature (ping / netstat / wake-on-LAN pages), so its post-authentication command execution is most likely treated as intended administrative functionality rather than a novel vulnerability. The submission-worthy question is condition (a) — whether any dispatch path reaches the setter pre-authentication. ASUS has auth-bypass precedent (CVE-2021-32030, GT-AC2900; CVE-2017-6549, RT-AC53), so a confirmed pre-auth path would be significant.

Hardcoded get_auth_code secret and lan_ifname newline gap. No prior CVE surfaced for either. Both warrant individual consideration, though the lan_ifname gap is post-auth-only and the hardcoded-secret impact depends on what the primitive gates.

Bottom line. Finding A is not novel as a vulnerability class. Its value rests on the handler-ungated result (condition a closed to the static boundary) and any demonstrated HTTP-layer bypass — the class of finding that produced CVE-2021-32030 and CVE-2017-6549 on other ASUS models. Finding D is already resolved by the vendor in 53370. Confirm CVE mapping against ASUS's PSIRT advisory list before submission.